

Resumen Ejecutivo

Auditoría de Seguridad — Aplicación ArchivaCloud P-10

Dirigido a la gerencia de CloudConta SpA

Introducción

Somos un equipo de consultores externos de ciberseguridad y fuimos contratados por CloudConta SpA para realizar una auditoría de seguridad sobre su más reciente aplicación, ArchivaCloud P-10, desarrollada por su equipo de TI para la gestión de documentos en la nube. El objetivo de esta auditoría fue identificar los riesgos de seguridad del sistema antes de que entre en operación con usuarios y datos reales. En este documento se resumen los resultados en un lenguaje orientado a la gerencia; el detalle técnico se encuentra en el informe completo.

Estado general

Durante la auditoría se identificaron 13 hallazgos de seguridad validados, de los cuales 1 es de gravedad crítica, 4 de gravedad alta, 7 de gravedad media y 1 de carácter informativo. Debido a esto, se concluye que la aplicación presenta un nivel de seguridad deficiente y que no debería desplegarse en producción sin antes aplicar las correcciones recomendadas.

El riesgo más grave

El hallazgo más grave es que la aplicación no exige ninguna identificación para operar, por lo que cualquier persona que conozca la dirección del servidor puede consultar, descargar y eliminar todos los documentos almacenados sin necesidad de una cuenta ni contraseña. Esto implica que, desde el momento en que la aplicación se publique, la información de los clientes de CloudConta SpA quedaría completamente expuesta.

Otros riesgos relevantes

Además, se detectó que un atacante podría reemplazar documentos existentes por versiones falsificadas, y que dicha acción no dejaría rastro ni podría revertirse, ya que la aplicación no conserva versiones anteriores de los archivos ni mantiene un registro de quién accede o modifica la información. También se identificaron componentes de software con fallas de seguridad conocidas que requieren actualización.

Aspectos correctamente implementados

No todo presenta deficiencias. Se dejó constancia de que el almacenamiento no es accesible públicamente desde internet, de que la aplicación mitiga por diseño un tipo común de ataque en el navegador, y de que las restricciones de acceso entre distintos sitios web están correctamente configuradas. Estos controles constituyen una base sobre la cual construir las mejoras.

Recomendaciones prioritarias

En orden de impacto, se recomienda:

- **Control de acceso:** implementar un sistema de autenticación que exija identificación antes de acceder a la aplicación, como medida indispensable previa a cualquier publicación.
- **Recuperación de datos:** habilitar el historial de versiones del almacenamiento, para poder recuperar los documentos ante una sobrescritura o un borrado.

- **Gestión de credenciales:** trasladar las credenciales de acceso a la nube a un sistema de gestión segura de secretos, otorgando solo los permisos estrictamente necesarios.
- **Trazabilidad:** activar el registro de accesos, para tener trazabilidad de las acciones realizadas y poder investigar cualquier incidente.
- **Mantenimiento:** actualizar los componentes de software que presentan vulnerabilidades conocidas.

Conclusión

Los resultados confirman que ArchivaCloud P-10 requiere una intervención de seguridad importante antes de entrar en producción. Sin embargo, todos los hallazgos identificados son corregibles mediante controles conocidos y de bajo costo relativo, por lo que la aplicación de estas recomendaciones permitiría llevar el sistema desde su estado vulnerable actual hacia uno acorde a las buenas prácticas de la industria, protegiendo adecuadamente la información de los clientes de CloudConta SpA.